Chapter 10

Security Policies

Chapter Objectives

After reading this chapter and completing the exercises, you will be able to do the following:

- Recognize the importance of security policies.
- Understand the various policies and the rationale for them.
- Know what elements go into good policies.
- Create policies for network administration.
- Evaluate and improve existing policies.

Introduction

So far in this book we have explored various threats to networks. And in Chapter 9, "Computer Security Software," we examined a variety of technical defenses against such attacks. However, the fact is that technology by itself cannot solve all network security problems. There are some issues that technology cannot stop. Examples of this include the following:

- Virus software won't prevent a user from manually opening an attachment and releasing a virus.
- A technologically secured network is still very vulnerable if former employees (perhaps some unhappy with the company) still have working passwords. Or if passwords are simply put on Post-it notes on computer monitors.
- A server is not secure if it is in a room that nearly everyone in the company has access to.
- Your network is not secure if end users are vulnerable to social engineering.

Another reason that technology alone is not the answer is that technology must be appropriately applied. Policies are used to guide you in how to implement and manage security, including security technology. In this chapter, we will examine computer security policies, including the elements that go into creating good security policies as well as examples of how to establish a network security policy.

What Is a Policy

A security policy is a document that defines how an organization will deal with some aspect of security. There can be policies regarding end-user behavior, IT response to incidents, or policies for specific issues and incidents.

Security policies can also be created to deal with regulatory requirements. These types of policies direct members of the organization as to how to comply with certain regulations. A good example would be a policy informing healthcare workers how to comply with HIPAA when using electronic medical records software.

Or policies can simply be advisory, advising employees how they should handle certain items, but not requiring compliance. For example a policy might advise users that emailing from a smart phone using a WiFi hotspot can be unsecure, but not forbid it.

Defining User Policies

When discussing user policies, there is one rule you must keep in mind: You should have a policy for every foreseeable situation. Failure to have policies that address a given problem will usually result in that problem being exacerbated. Something may seem like common sense to you, but may not be to someone with no training or experience in computer networks or network security.

The misuse of systems is a major problem for many organizations. A large part of the problem comes from the difficulty in defining exactly what is misuse. Some things might be obvious misuse, such as using company time and computers to search for another job or to view illicit websites. However, other areas are not so clear, such as an employee using her lunchtime to look up information about a car she is thinking of buying. Generally, good user policies will outline specifically how people are to use the system and how they should not. For a policy to be effective, it needs to be very clear and quite specific. Vague statements such as “computers and Internet access are only for business use” are simply inadequate. I would recommend something more clear and perhaps more enforceable, perhaps something like “computers and Internet access are only for business purposes during business hours. However, employees may use the computer/Internet access for personal use during nonwork time such as breaks, lunch, and before work. However, such use must be in compliance with Internet usage policies.” That is clear, direct, and also enforceable.

Other areas for potential misuse are also covered by user policies, including password sharing, copying data, leaving accounts logged on while employees go to lunch, etc. All of these issues ultimately have a significant impact on your network’s security and must be clearly spelled out in your user policies. We will now examine several areas that effective user policies must cover:

- Passwords
- Internet use
- Email attachments
- Installing/uninstalling software
- Instant messaging
- Desktop configuration

Passwords

Keeping passwords secure is critical. In Chapter 8, "Encryption," appropriate passwords were discussed as part of operating system hardening. A good password is at least eight characters long, uses numbers and special characters, and has no obvious relevance to the end user. For example, a Dallas Cowboys fan would be ill advised to use a password like *cowboys* or *godallas*, but might be well advised to use a password such as *%trEe987* or *123DoG$$*, since those don't reflect the person's personal interests and therefore would not be easily guessed. Issues such as minimum password length, password history, and password complexity come under administrative policies, not user policies. User policies dictate how the end user should behave. For reliable security, I recommend a passphrase that has been altered to include numbers and special characters. This can be something easy to remember but altered so that it will not be vulnerable to guessing or brute-force attacks. An example would be taking the phrase "I like double cheese burgers" and altering it to be IliK3double3ch33$eburg3r$. Notice the e's were changed to 3's, the s's to $'s and two random letters were capitalized. You now have a 25-character password that is also complex. It is easy to remember and very difficult to break.

However, no password is secure, no matter how long or how complex, if it is listed on a sticky note stuck to the user's computer monitor. This may seem obvious, but it is not at all uncommon to go into an office and find a password either on the monitor or in the top drawer of the desk. Every janitor or anyone who simply passes by the office can get that password.

It is also not uncommon to find employees sharing passwords. For example, Bob is going to be out of town next week, so he gives Juan his password so that Juan can get into his system, check email, etc. The problem is that now two people have that password. And what happens if during the week Bob is gone, Juan gets ill and decides he will share the password with Shelly so that she can keep checking that system while Juan is out sick? It does not take long for a password to get to so many people that it is not longer useful at all from a security perspective.

Issues like minimum length of passwords, password age, and password history are issues of administrative policies. System administrators can force these requirements. However, none of that will be particularly helpful if the users don't manage their passwords in a secure fashion.

All of this means you need explicit policies regarding how users secure their passwords. Those policies should specify the following:

- Passwords are never to be kept written down in any accessible place. The preference is that they not be written down at all, but if they are, they should be in a secure area such as a lock box at your home (i.e., not in the office right next to your computer).
- Passwords must never be shared with any person for any reason.
- If an employee believes his password has been compromised, he should immediately contact the IT department so his password can be changed and so that logon attempts with the old password can be monitored and traced.

Internet Use

Most organizations provide their users with some sort of Internet access. There are several reasons for this. The most obvious reason is email. However, that is hardly the only reason to have Internet access in a business or academic setting. There is also the Web, and even chat rooms (believe it or not, they can, and in some cases are being used for business communications). All of which can be used for legitimate purposes within any organization, but can also be serious security problems. Appropriate polices must be in place to govern the use of these technologies.

The World Wide Web is a wonderful resource for a tremendous wealth of data. Throughout this book, we have frequently referenced websites where one can find valuable security data and useful utilities. The Internet is also replete with useful tutorials on various technologies. However, even non-technology-related business interests can be served via the Web. Here are a few examples of legitimate business uses of the Web:

- Sales staff checking competitor's websites to see what products or services they offer, in what areas, perhaps even getting prices
- Creditors checking businesses AM Best or Standard and Poor's rating to see how their business financial rating is doing
- Business travelers checking weather conditions, and getting prices for travel
- Online training with webinars
- Web meetings
- Online bill payment or in some cases even filing regulatory and government documents

Of course, there are other web activities that are clearly not appropriate on a company's network:

- Using the Web to search for a new job
- Any pornographic use
- Any use which violates local, state, or federal laws
- Use of the Web to conduct your own business (i.e., you have another enterprise you are involved in other than the company's business)

In addition, there are gray areas. Some activities might be acceptable to some organizations, but not to others. Such activities might include

- Online shopping during the employee's lunch or break time
- Reading news articles online during lunch or break time
- Viewing humorous websites

What one person might view as absurdly obvious might not be to another. It is critical that any organization have very clear policies detailing specifically what is and what is not acceptable use of the Web at work. Giving clear examples of what is acceptable use and what is not is also important. You should also remember that most proxy servers and many firewalls can block certain websites. This will help prevent employees from misusing the company's web connection.

Email Usage

Most business and even academic activity now occurs via email. As we have discussed in several previous chapters, email also happens to be the primary vehicle for virus distribution. This means that email security is a significant issue for any network administrator.

Clearly you cannot simply ban all email attachments. However, you can establish some guidelines for how to handle email attachments. Users should only open an attachment if it meets the following criteria:

- It was expected (i.e., they requested documents from some colleague or client).
- If it was not expected, did it come from a known source? If so first send that person an email (or phone them) and ask if they sent the attachment. If so open it.
- It appears to be a legitimate business document (i.e., a spreadsheet, a document, a presentation, etc.).

It should be noted that some people might find such criteria unrealistic. There is no question they are inconvenient. However, with the prevalence of viruses, often attached to email, these measures are prudent. Many people choose not to go to this level to try and avoid viruses, and that may be your choice as well. Just bear in mind that millions of computers are infected with some sort of virus every single year.

No one should ever open an attachment that meets any of the following criteria:

- It comes from an unknown source.
- It is some active code or executable.
- It is an animation/movie.
- The email itself does not appear legitimate. (It seems to entice you to open the attachment, rather than simply being a legitimate business communication that happens to have an attachment.)

If the end user has any doubt whatsoever, then she should not open the email. Rather, she should contact someone in the IT department who has been designated to handle security. That person can then either compare the email subject line to known viruses or can simply come check out the email personally. Then if it appears legitimate the user can open the attachment.

FYI: About Attachments

The author of this book frequently follows "better safe than sorry" axiom on this matter. This means that when forwarded some joke, image, flash animation, etc. circulating the Internet, I simply delete it. That may mean that I will miss many humorous images and stories, but it also means I will miss many viruses. You would do well to consider emulating this practice.

Installing/Uninstalling Software

This is one matter that does have an absolute answer. End users should not be allowed to install anything on their machine. This includes wallpapers, screensavers, utilities—anything. The best approach is to limit their login privileges so that they cannot install anything. However, this should be coupled with a strong policy statement prohibiting the installation of anything on their PC. If they wish to install something, it should first be scanned by the IT department and approved. This process might be cumbersome but it is necessary. Some organizations go so far as to remove or at least disable media drives (CD, floppy, USB, etc.) from end-user PCs, so installations can only occur from files that the IT department has put on some network drive. This is usually a more extreme measure than most organizations will require but it is an option you should be aware of. In fact, Windows allows the administrator to disable allowing new USB devices. So the admin can install some USB devices that are approved for corporate use, then disallow any additional devices being added.

Instant Messaging

Instant messaging is also widely used and abused by employees in companies and organizations. In some cases, instant messaging can be used for legitimate business purposes. However, it does pose a significant security risk. There have been viruses which specifically propagated via instant messaging. In one incident, the virus would copy everyone on the user's buddy list with the contents of all conversations. Thus a conversation you thought was private was being broadcast to everyone you knew and had messaged with.

Instant messaging is also a threat from a purely informational security perspective. Nothing stops an end user from instant messaging out trade secrets, or confidential information, without the traceability of email going through the corporate email server. It is recommended that instant messaging simply be banned from all computers within an organization. If you find you absolutely must have it, then you must establish very strict guidelines for its use, including the following:

- Instant messaging can only be used for business communications, no personal conversations. Now this might be a bit difficult to enforce. Rules like this often are. More common rules, such as prohibiting personal web browsing, are also quite difficult to enforce. However it is still a good idea to have those rules in place. Then if you find a person violating them, you do have a company policy that you can refer to that prohibits such actions. However, you should be aware that in all likelihood you won't catch most violations of this rule.
- No confidential or private business information should be sent via instant messaging.

Desktop Configuration

Many users like to reconfigure their desktop. This means changing the background, screensaver, font size, resolution, etc. Theoretically speaking, this is not a security hazard. Simply changing your computer's background image cannot compromise your computer's security. However, there are other issues involved.

The first issue is where the background image comes from. Frequently, end users will download images from the Internet. This means there is a chance of getting a virus or Trojan horse, particularly one using a hidden extension (i.e., it appears to be a mypic.jpg but is really mypic.jpg.exe). There are also human resources/harassment issues if an employee uses a backdrop or screensaver that is offensive to other employees. Some organizations simply decide to prohibit any changes to the system configuration for this reason.

The second problem is technical. In order to give a user access to change screensavers, background images, and resolution, you must give them rights which will also allow them to change other system settings you might not want changed. The graphical display options are not separated from all other configuration options. This means that allowing the user to change their screensaver might open the door for them to alter other settings (such as the network card configuration or the Windows Internet Connection Firewall) that would compromise security.

Final Thoughts on User Policies

This section has provided an overview of appropriate and effective user policies. It is critical that any organization implement solid user policies. However, these policies will not be effective unless you have clearly defined consequences for violating them. Many organizations find it helpful to spell out specific consequences that escalate with each incident, such as the following:

- The first incident of violating any of these policies will result in a verbal warning.
- A second incident will result in a written warning.
- The third incident will result in suspension or termination. (In the case of academic settings, this would be suspension or expulsion.)

You must clearly list the consequences, and all users should sign a copy of the user policies upon being hired. This prevents anyone claiming they where not aware of the policies.

CAUTION

Termination or Expulsion

Any policy which can lead to expulsion from a school or termination from a job (or even a demotion) should first be cleared by your legal advisor. There can be significant legal ramifications for wrongful termination or expulsion. The author of this book is not an attorney, nor an expert in legal matters, and cannot provide you with legal advice. It is imperative that you do consult an attorney about these matters.

It is also important to realize that there is another cost to misuse of corporate Internet access. That cost is lost productivity. How much time does the average employee spend reading personal email, doing nonbusiness web activities, or instant messaging? It is hard to say. However, for an informal view, go to www.yahoo.com on any given business day, during business hours, and click on one of the news stories. At the bottom of the story you will see a message board for this story. It lists date and time of posts. See how many posts are done during business hours. It is unlikely that all of those people are out of work, retired, or at home sick.

Let us be completely clear. The Internet is the single greatest communication tool in human history. And it can have a tremendous positive effect on any business. I personally conduct almost all of my business activities through the Web. However, many employees do abuse the Internet, and it does decrease productivity for those who cannot be self-disciplined. Here are just a few studies supporting this assertion:

- A 2008 study showed employees wasting an average of 5.3 hours a week on idle Internet surfing.
- Ohio State University researchers found regular Facebook users had a lower GPA than nonusers (http://redandblack.com/2009/04/29/social-networking-decreases-productivity/)
- A 2010 study showed allowing Facebook access on the business network lead to a 1.5% loss in overall productivity. Some employees admitted to spending as much as 2 hours per day on Facebook while at work (www.techjournalsouth.com/2010/08/social-networking-at-work-leads-to-productivity-loss/).

Defining System Administration Policies

In addition to determining policies for users, you must have some clearly defined policies for system administrators. There must be a procedure for adding users, removing users, dealing with security issues, changing any system, etc. There must also be standards for handling any deviation.

New Employees

When a new employee is hired, the system administration policy must define specific steps to safeguard company security. New employees must be given access to the resources and applications their job function requires. The granting of that access must be documented (possibly in a log). It is also critical that the new employee receive a copy of the company's computer security/acceptable use polices and sign a document acknowledging receipt of such.

Before a new employee starts to work, the IT department (specifically network administration) should receive a written request from the business unit that person will be working for. That request should specify exactly what resources this user will need, when she will start, and have the signature of someone in the business unit with authority to approve such a request. Then the person who is managing network administration or network security should approve and sign the request. After you have implemented the new user on the system with the appropriate rights, you can file a copy of the request.

Departing Employees

When an employee leaves, it is critical to make sure all of his logins are terminated and all access to all systems is discontinued immediately. Unfortunately, this is an area of security that all too many organizations do not give enough attention to. When an employee leaves, you cannot be certain which employee will bear the company ill will, and which won't. It is imperative to have all of the former employee's access shut down on his last day of work. This includes physical access to the building. If a former employee has keys and is disgruntled, nothing can stop him from returning to steal or vandalize computer equipment. When an employee leaves the company, you need to ensure that on his last day the following actions take place:

- All logon accounts to any server, VPN, network, or other resource are disabled.
- All keys to the facility are returned.
- All accounts for email, Internet access, wireless Internet, cell phones, etc. are shut off.
- Any accounts for mainframe resources are canceled.
- The employee's workstation hard drive is searched.

The last item might seem odd. But if an employee was gathering data to take with him (proprietary company data) or conducting any other improper activities, you need to find out right away. If you do see any evidence of any such activity, you need to secure that workstation and keep it for evidence in any civil or criminal proceedings.

All of this might seem a bit extreme to some readers. It is true that with the vast majority of exiting employees you will have no issues to be concerned about. However, if you do not make it a habit of securing an employee's access when they depart, you will eventually have an unfortunate situation that could have been easily avoided.

Change Requests

The nature of IT is change. Not only do end users come and go, but requirements change frequently. Business units request access to different resources, server administrators upgrade software and hardware, application developers install new software, web developers change the website, etc. Change is occurring all the time. Therefore, it is important to have a change control process. This process not only makes the change run smoothly, but allows the IT security personnel to examine the change for any potential security problems, before it is implemented. A change control request should go through the following steps:

- An appropriate manager within the business unit signs, signifying approval of the request.
- The appropriate IT unit (database administration, network admin, email admin, etc.) verifies that the request is one they can fulfill (from both a technological and a budgetary/business perspective).
- The IT security unit verifies that this change will not cause any security problems.
- The appropriate IT unit formulates a plan to implement the change and a plan to roll back the change in the event of some failure.
- The date and time for the change is scheduled, and all relevant parties are notified.

Your change control process might not be identical to this one; in fact, you might be much more specific. However the key to remember is that in order for your network to be secure, you simply cannot have changes happening without some process for examining the impact of those changes prior to implementing them.

In Practice

Extremes of Change Control

Anyone with even a few years of experience in the IT profession can tell you that when it comes to change control there are all sorts of different approaches. The real problem is those IT groups that implement unreasonable extremes. This author has personally seen both. Without using the real names of the companies involved, let's examine a real case of each extreme.

Software consultants company X was a small company that did custom financial applications for various companies. They had a staff of less than 20 developers, who frequently traveled to client locations around the country. They literally had

- No documentation for any of their applications, not even a few notes.
- There was no change control process at all. When someone did not like a setting on a server, or some part of the network configuration, they simply changed it.
- There was no process for handling former employee access. In one case, a person had been gone for six months and still had a valid logon account.

Now clearly this is alarming from several perspectives, not just from a security viewpoint. However, that is one extreme, one that makes for a very chaotic environment that is very unsecure. Security-minded network administrators tend to move toward the opposite extreme, one which can have a negative impact on productivity.

Company B had over 2,000 employees, with an IT staff of about 100 people. In this company, however, the bureaucracy had overwhelmed the IT department to the point that their productivity was severely impacted. In one case, a person was a web server administrator and the decision had been made that he also needed database administration rights on a single database server. The process, however, took three months with one face-to-face meeting between his manager and the CIO, as well as two phone conferences and a dozen emails between his manager and the manager of the database group.

The company's convoluted change control process had a severely negative impact on productivity. Some employees informally estimated that even the low-level IT supervisors spent 40% of their time in meetings/conferences, reporting on meetings/conferences, or preparing for meetings/conferences. And the further one went up the IT ladder, the more one's time became consumed in bureaucratic activities.

Both of these examples are meant to illustrate two extremes in change control management that you should try to avoid. Your goal in implementing change control management is simply to have an orderly and safe way of managing change, not to be an impediment to productivity.

Security Breaches

Unfortunately, the reality is that your network will probably, at some point, have a security breach of some kind. This could mean that you are the target of a denial of service attack, your system is infected with a virus, or perhaps a hacker gains entrance and destroys or copies sensitive data. You must have some sort of plan for how to respond should any such event occur. This book cannot tell you specifically how to deal with each and every event that might occur; however, we can discuss some general guidelines for what to do in certain, general, situations. We will look at each of the main types of security breaches and what actions you should take for each.

Virus Infection

- When a virus strikes your system, immediately quarantine the infected machine or machines. This means literally unplugging the machines from the network. If it is a subnet, then unplug its switch and/or disconnect wireless access. Isolate the infected machines (unless your entire network is infected, in which case simply shut down your router/ISP connection to close you off from the outside world and prevent spread beyond your network). After implementing the quarantine, you can safely take the following steps.
- Scan and clean each and every infected machine. Since they are now off the network, this will be a manual scan.

- Log the incident, the hours/resources taken to clean the systems, and the systems which where affected.
- When you are certain the systems are clean, bring them online in stages (a few at a time). With each stage, check all machines to see that they are patched, updated, and have properly configured/running antivirus.
- Notify the appropriate organization leaders of the event and the actions you have taken.
- After you have dealt with the virus and notified the appropriate people, you should then have a meeting with appropriate IT staff to discuss what can be learned from this breach, and how you might prevent it from occurring in the future.

Denial of Service Attacks

- If you have taken the steps outlined earlier in this book (such as properly configuring your router and your firewall to reduce the impact of any attempted DoS), then you will already be alleviating some of the damage from this type of attack. Use your firewall logs or IDS to find out which IP address (or addresses) originated the attacks. Note the IP addresses, then (if your firewall supports this feature, and most do) deny that IP address access to your network.
- Use online resources (interNIC.net, etc.) to find out who the address belongs to.
- Contact that organization and inform them of what is occurring.
- Log all of these activities and inform the appropriate organizational leaders.
- After you have dealt with the DoS and notified the appropriate people, you should then have a meeting with appropriate IT staff to discuss what can be learned from this attack, and how you might prevent it from occurring in the future.

Intrusion by a Hacker

- Immediately copy the logs of all affected systems (firewall, targeted servers, etc.) for use as evidence.
- Immediately scan all systems for Trojan horses, changes to firewall settings, changes to port filtering, new services running, etc. In essence, you are performing an emergency audit to see what damage has been done.
- Document everything. Of all of your documentation, this must be the most thorough. You must specify which IT personnel took what actions at what times. Some of this data may be part of later court proceedings, so absolute accuracy is necessary. It is probably a good idea to log all activities taken during this time and to have at least two people verify and sign the log.
- Change all affected passwords. Repair any damage done.

- Inform the appropriate business leaders of what has happened.
- After you have dealt with the breach and notified the appropriate people, you should then have a meeting with appropriate IT staff to discuss what can be learned from this breach and how you might prevent it from occurring in the future.

These are just general guidelines, and some organizations may have much more specific actions they want taken in the event of some security breach. You should also bear in mind that throughout this book when we have discussed various sorts of threats to network security we have mentioned particular steps and policies that should be taken. The policies in this chapter are meant to be in addition to any already outlined in this book. It is an unfortunate fact that some organizations have no plan for what to do in case of an emergency. It is important that you do have at least some generalized procedures you can implement.

Defining Access Control

An important area of security policies that usually generates some controversy in any organization is access control. There is always a conflict between users' desire for unfettered access to any data or resources on the network and the security administrator's desire to protect that data and resources. This means that extremes in policies are not practical. You cannot simply lock down every resource as completely as possible, since that would impede the user's access to those resources. Conversely, you cannot simply allow anyone and everyone complete access to everything. The core of access control is the concept introduced in Chapter 1: least privileges. Each person is given the minimum privileges necessary to do his or her job. No more and no less.

This is where the least privileges concept comes into play. The idea is simple. Each user, including IT personnel, gets the least access they can have and still effectively do their job. Rather than ask the question "why not give this person access to X?" you should ask "why give this person access to X?" And if you don't have a very good reason, then don't. This is one of the fundamentals of computer security. The more people that have access to any resource, the more likely some breach of security is to occur.

Along with, and related to, least privileges is the concept of implicit deny. Implicit deny means that all users are implicitly denied access to network resources until an administrator explicitly grants them.

Separation of duty, job rotation, and mandatory vacations are also important and related concepts. Separation of duty means that no one person can perform critical tasks; at least two individuals are needed. This prevents one person from accidently, or intentionally, causing some security breach via inappropriate use of critical functions. Job rotation and mandatory vacations are both used to make sure that, periodically, the person performing a given job changes. This makes it more difficult for one person to exploit his or her position to breach security.

Obviously, trade-offs must be made between access and security. Examples abound. One common example involves sales contact information. Clearly, a company's marketing department needs access to this data. However, what happens if ones competitors get all of your company's contact information?

That could allow them to begin targeting your current client list. This requires a trade-off between security and access. In this case, you would probably give salespeople access only to the contacts that are within their territory. No one other than the sales manager should have complete access to all the marketing data.

Developmental Policies

Many IT departments include programmers/web developers. Unfortunately, many security policies do not address secure programming. No matter how good your firewalls, proxy server, virus scanning, and policies are, if your developers create code that is flawed, you will have security breaches. Clearly the topic of secure programming requires a separate volume to explore thoroughly. Nonetheless, we can consider a brief checklist for defining secure development policies. If your company currently has no secure programming initiatives, this checklist is certainly better than developing in a vacuum. It can also serve as a starting point to get you thinking, and talking, about secure programming:

- All code, especially code done by outside parties (contractors, consultants, etc.) must be checked for back doors/Trojan horses.
- All buffers must have error handling which prevents buffer overruns.
- All communication (such as using TCP sockets to send messages) must adhere to your organization's secure communications guidelines.
- Any code that opens any port or performs any sort of communication is thoroughly documented and the IT security unit is apprised of the code, what it will do, and how it will be used.
- All input is filtered for items that might facilitate an attack such as an SQL injection attack.
- All vendors should supply you with a signed document verifying that there are no security flaws in their code.

Following these guidelines will not guarantee that no flawed code gets introduced into your system, but it will certainly lower the odds, significantly. And the unfortunate fact is that these simple steps alone are more than most organizations are taking. A very good place to look at security policies is the SANS Institute (www.sans.org/security-resources/policies/).

Standards, Guidelines, and Procedures

Related to policies are standards, guidelines, and procedures. All of these documents are related to security policies and in fact support those policies. A standard is a general statement of the desired level of operation. For example, requiring 99.5% network uptime would be a standard. A guideline is a general suggestion on how to achieve some standard. Guidelines are broad and are sometimes optional (i.e., not mandatory). Finally, we have procedures. Procedures are specific instructions on how to handle a specific issue.

Summary

In this chapter, you learned the technology is not enough to ensure a secure network. You must have clear and specific policies detailing procedures on your network. Those policies must cover employee computer resource use, new employees, outgoing employees, access rights, how to respond to an emergency, and even how secure code in applications and websites is.

User policies must cover all aspects of how the user is expected to use company technology. In some cases, such as instant messaging and web use, policies may be difficult to enforce, but that does not change the fact that they must still be in place. If your user policies fail to cover a particular area of technology use, then you will have difficulty taking any action against any employee who performs that particular misuse.

We also learned that it is not just the end user who will need policies. The IT staff needs clearly delineated policies covering how to handle various situations. Of particular concern will be policies dictating how to handle new users or exiting users. You also need a carefully considered change management policy.

Test Your Skills

MULTIPLE CHOICE QUESTIONS

1. Which of the following does not demonstrate the need for policies?
   - A. Antivirus software cannot prevent a user from downloading infected files.
   - B. The most secure password is not at all secure if posted on a note by the computer.
   - C. End users are generally not particularly bright and must be told everything.
   - D. Technological security measures are dependent upon the employees' implementation.
2. Which of the following is not an area the user policies need to cover?
   - A. Minimum length of passwords
   - B. What websites one can or cannot visit
   - C. If and when to share passwords
   - D. What to do if you believe your password has been compromised
3. Which of the following is not an example of a user password policy?
   - A. Users may not keep copies of passwords in their office.
   - B. Passwords must be eight characters long.
   - C. Users may only share passwords with their assistant.
   - D. Passwords may not be shared with any employee.

4. What should an employee do if she believes her password has been revealed to another party?
   - A. If it is a trusted employee or friend, just ignore it.
   - B. Change your own password immediately.
   - C. Notify the IT department.
   - D. Ignore it.

5. Which of the following should not be recommended as acceptable email attachments?
   - A. Flash animations
   - B. Excel spreadsheets from a colleague
   - C. Attachments you where expecting
   - D. Plain text attachments from known sources

6. Which of the following is the best reason users should be prohibited from installing software?
   - A. They may not install it correctly which could cause security problems for the workstation.
   - B. They may install software that circumvents security.
   - C. Software installation is often complex and should be done by professionals.
   - D. If a users account does not have privileges to install, then it is likely that a Trojan horse will not be inadvertently installed under their account.

7. Which of the following is not a significant security risks posed by instant messaging?
   - A. Employees may send harassing messages.
   - B. Employees might send out confidential information.
   - C. A virus or worm might infect the workstation via instant messaging.
   - D. An instant messaging program could actually be a Trojan horse.

8. What must all user policies have in order to be effective?
   - A. They must be reviewed by an attorney.
   - B. They must have consequences.
   - C. They must be notarized.
   - D. They must be properly filed and maintained.

9. Which of the following is the appropriate sequence of events for a new employee?
   - A. IT is notified of the new employee and the requested resources > employee is granted access to those resources > employee is briefed on security/acceptable use > employee signs acknowledging receipt of a copy of security rules.
   - B. IT is notified of the new employee and the requested rights > employee is given access to those resources> employee signs acknowledging a receipt of a copy of security rules.

C. IT is notified of the new employee and assigns default rights > employee is briefed on security/acceptable use > employee signs acknowledging receipt of a copy of security rules.

D. IT is notified of the new employee and assigns default rights> employee signs acknowledging receipt of company security rules.

10. Which of the following is the appropriate sequence of events for a departing employee?

A. IT is notified of the departure > all logon accounts are shut down > all access (physical and electronic) is disabled.

B. IT is notified of the departure > all logon accounts are shut down > all access (physical and electronic) is disabled > the employee's workstation is searched/scanned.

C. IT is notified of the departure > all physical access is shut down > all electronic access is shut down.

D. IT is notified of the departure > all electronic access is shut down > all physical access is shut down.

11. Which of the following is the appropriate sequence for a change request?

A. Business unit manager requests change > IT unit verifies request > request is implemented.

B. Business unit manager requests change >IT unit verifies request > security unit verifies request > request is scheduled with rollback plan > request is implemented.

C. Business unit manager requests change >IT unit verifies request >request is scheduled with rollback plan > request is implemented.

D. Business unit manager requests change > IT unit verifies request > security unit verifies request > request is implemented.

12. What is the first step when discovering a machine or machines has been infected with a virus?

A. Log the incident

B. Scan and clean infected machines

C. Notify appropriate management

D. Quarantine infected machines

13. What is the rule in access control?

A. The most access you can securely give

B. The least access job requirements allow

C. Standard access for all users

D. Strictly limited access for most users

14. After dealing, on a technical level, with any security breach, what is the last thing to be done for any security breach?

    A. Quarantine infected machines
    B. Study the breach to learn how to prevent a recurrence
    C. Notify management
    D. Log the incident

15. Which of the following is a list of items that should be implemented in all secure code?

    A. All code checked for back doors or Trojans, all buffers have error handling to prevent buffer overruns, all communication activity thoroughly documented.
    B. All code checked for back doors or Trojans, all buffers have error handling to prevent buffer overruns, all communications adheres to organizational guidelines, all communication activity thoroughly documented.
    C. All code checked for back doors or Trojans, all buffers have error handling to prevent buffer overruns, all communication adheres to organizational guidelines.
    D. All code checked for back doors or Trojans, all communication adheres to organizational guidelines, all communication activity thoroughly documented.

EXERCISES

Each of these exercises is intended to give the student experience writing limited portions of a policy. Taken together the exercises represent a complete policy for a college campus computer network.

EXERCISE 10.1: User Policies

Using the guidelines provided in this chapter (and other resources as needed), create a document that defines user policies. The policies should clearly define acceptable and unacceptable use for all personnel. You may require some separate policies for administration, faculty, and students.

EXERCISE 10.2: New Student Policy

Using the guidelines provided in this chapter (and other resources as needed), create a step-by-step IT security policy for implementing a new user account for a student.

The policy should define what resources the student has access to, what she does not have access to, and for how long access is granted.

EXERCISE 10.3: Leaving Student Policy

Using the guidelines provided in this chapter (and other resources as needed), create a step-by-step IT security policy for handling user accounts/rights for a student who is leaving prematurely (drops, is expelled, etc.).

You will need to consider specialized student scenarios, such as a student who works as an assistant to a faculty member or as a lab assistant in a computer lab and may have access to resources most students do not.

EXERCISE 10.4: New Faculty/Staff Policy

Using the guidelines provided in this chapter (and other resources as needed), create a step-by-step IT security policy for implementing a new user account for a faculty or staff member.

The policy should define what resources the faculty or staff member has access to, what she does not have access to, and any restrictions. (Hint: Unlike student policies, you won't need to define time length since it should be indefinite.)

EXERCISE 10.5: Leaving Faculty/Staff Policy

Write a policy for how to handle a faculty departure (quit, fired, retired, etc.). Use the guidelines in this chapter and any other resources you like to get you started.

Make certain you consider not only shutting down access but also the possibility of proprietary research material existing on the faculty/staff member's workstation.

EXERCISE 10.6: Student Lab Use Policy

Considering the material in this chapter, create a set of policies for acceptable use of computer lab computers.

Make sure to specify web use, email use, and any other acceptable uses.

Carefully spell out unacceptable usage (i.e., is game playing acceptable?).

PROJECTS

PROJECT 10.1: Examining Policies

1. Examine the following web resources that discuss security policies:
   - Level 3 acceptable use policy: www.level3.com/764.html
   - Earthlink acceptable use policy: www.earthlink.net/about/policies/use/
   - SANS Institute policies: www.sans.org/resources/policies/
   - Information Security Policy World: www.information-security-policies-and-standards.com/

2. Summarize the main theme of these policy recommendations. Pay particular attention to any area that these recommendations differ from or exceed the recommendations of this chapter.
3. Choose which policy recommendation you believe is the most secure and state the reasons for your choice.

PROJECT 10.2: Real-World Security Policies

Ask a local business, or your college, to let you see their security policies. Study the policies carefully.

1. Summarize the main theme of these policy recommendations. Pay particular attention to any area that these recommendations differ from or exceed the recommendations of this chapter.
2. Choose which policy recommendation you believe is the most secure and state the reasons for your choice.

PROJECT 10.3: Creating Security Policies

Note: This works well as a group project.

At this point in the book, you have studied security including policies. After this chapter and the proceeding exercises and projects, you have examined several polices from various web resources and the policies of some actual organizations.

Take the brief policies you created for the exercises in this chapter and expand them to create an entire working security policy for your college. You will need to add administrative policies, developmental policies, and more.

Case Study

Hector is a security administrator for a defense contractor. This business frequently works with highly sensitive, classified material. Hector has developed a policy for departing employees. This policy handles everything mentioned in this chapter:

- All logon accounts to any server, VPN, network, or other resource are disabled.
- All keys to the facility are returned.
- All accounts for email, Internet access, wireless Internet, cell phones, etc. are shut off.
- Any accounts for any mainframe resources are canceled.
- The employee's workstation hard drive is searched.

Given the highly sensitive nature of the work at this company, what other actions might you add to this policy?